

Cloud Shared Responsibility and Compliance Report

Name: Eugen Nyongesa

Date: June 22, 2026

I reviewed the organization's current security controls across both the on-premises and cloud sides of the hybrid environment and compared what is in place to the cloud security best practices we use as our baseline and to HIPAA's safeguards. The environment has a reasonable starting point, but I found several gaps that affect HIPAA compliance, the most pressing being unencrypted PHI backups, fragmented encryption keys, and access control that relies on manual role management with no reviews. My findings and the responsibilities behind them are laid out below, followed by prioritized recommendations.

Scope: Hybrid cloud environment (on-premises plus a cloud provider's platform) processing Protected Health Information, assessed against cloud security best practices and HIPAA.

1. Shared Responsibility Analysis

The table below splits responsibilities between the cloud provider and the healthcare organization for the hybrid environment. Because part of the estate is on-premises, several duties that would normally sit only with the customer in a pure-cloud setup are even more clearly the organization's to own.

Component	Cloud Provider Responsibility	Healthcare Organization Responsibility
Data Encryption	Encrypt data at rest on storage devices and provide encryption tools for customer use	Manage encryption keys securely, ensure consistent encryption policies across hybrid environment, and encrypt cloud backups
Access Control	Provide IAM tools, identity federation capabilities, and	Enforce MFA for all users, implement RBAC, conduct

	maintain the underlying identity infrastructure	periodic access reviews, and manage user lifecycle (onboarding/offboarding)
Monitoring and Incident Response	Maintain cloud-native logging tools, provide infrastructure-level monitoring, and notify customers of platform-wide incidents	Integrate logs from hybrid environment into centralized logging system, configure automated alerting, and update incident response plans to address hybrid cloud risks
Network Security	Secure physical network infrastructure, provide DDoS protection services, and maintain cloud network fabric	Configure security group rules, implement proper network segmentation, and update on-premises firewalls to support modern security features
Backup and Recovery	Enable automated backup services and provide infrastructure redundancy	Encrypt cloud backups, test disaster recovery procedures, and ensure backups meet compliance requirements
Patch Management	Patch the underlying hypervisor, physical infrastructure, and cloud platform components	Patch guest operating systems and applications running on cloud VMs
Physical Security	Secure data centers with access controls, surveillance, and environmental protections	N/A — Provider handles all physical security
Compliance and Auditing	Maintain compliance certifications (e.g., SOC 2,	Sign Business Associate Agreement (BAA), conduct

	HIPAA BAA) and provide compliance documentation	regular risk assessments, and maintain HIPAA compliance for PHI data
--	---	--

2. Cloud Security Architecture Evaluation

Here I assess each best practice as implemented, missing, or incomplete based on the scenario, with a note on the gap and why it matters.

Best Practice	Implemented (Yes/No/Partially)	Notes (Gap/Importance)
Data encryption at rest and in transit	Partially	Data stored in the cloud is encrypted at rest and in transit. However, cloud backups are not encrypted , creating a significant vulnerability. Encryption of backups is critical to prevent data exposure if backup storage is compromised.
Centralized key management	No	Encryption keys for on-premises and cloud environments are managed using different systems with no centralized control . This creates administrative overhead, increases the risk of key

		mismanagement, and makes key rotation difficult. Centralized key management is essential for consistent security and simplified administration.
Multi-factor authentication (MFA)	No	MFA is not currently enforced. Without MFA, accounts are vulnerable to credential theft and phishing attacks. This is a critical gap, especially for accessing PHI.
Principle of least privilege	Partially	User roles exist but are manually managed with no defined lifecycle and no periodic access reviews. Least privilege is not effectively enforced; permissions may persist after role changes or employee departure.
Automated monitoring, logging, alerting	Partially	The cloud provider offers built-in monitoring tools, but logs are not centralized across the hybrid environment, limiting threat detection and incident response.
Network segmentation	Partially	On-premises and cloud environments exist, but

		segmentation could be improved. Cloud VMs are exposed to the internet for administrative access, and outdated on-premises firewalls lack modern security features like deep packet inspection.
Regular vulnerability assessments	No	No mention of regular vulnerability assessments. Without ongoing scanning, new vulnerabilities remain unaddressed, increasing the risk of exploitation.
Documented and tested disaster recovery plans	Partially	Backups exist, but they are not encrypted . The scenario does not indicate whether DR plans are documented and tested. Unencrypted backups and untested DR plans create compliance and recovery risks.

3. HIPAA Compliance Comparison

This maps the current practices onto HIPAA's safeguard categories and flags where the organization falls short or where responsibility is correctly placed.

HIPAA Requirement	Current Practice	Gap or Improvement Needed
Administrative Safeguards — Security Management Process	No formal risk assessment process documented	Conduct annual security risk assessments and update policies accordingly. Document findings and remediation plans.
Administrative Safeguards — Assigned Security Responsibility	Security responsibilities not clearly assigned	Designate a formal Security Officer role with defined responsibilities for both on-premises and cloud environments.
Administrative Safeguards — Workforce Security	No defined lifecycle for account deactivation; no periodic access reviews	Implement formal onboarding and offboarding procedures for access management. Conduct quarterly access reviews.
Administrative Safeguards — Information Access Management	Cloud-based user roles are manually managed with no lifecycle management	Implement formal approval workflows for access requests. Use automated identity lifecycle management tools.

Administrative Safeguards — Security Awareness Training	No formal training program mentioned	Implement mandatory security awareness training for all employees handling PHI. Include hybrid cloud-specific risks.
Administrative Safeguards — Security Incident Procedures	Incident response plans do not account for hybrid cloud-specific risks	Update incident response plans to address hybrid cloud risks. Test plans annually.
Physical Safeguards — Facility Access Controls	Cloud provider ensures data center security	No gap identified— provider handles physical security for cloud infrastructure.
Technical Safeguards — Access Control	MFA is not enforced; no periodic access reviews	Enable MFA for all user accounts. Enforce strict access controls. Implement automated access reviews.
Technical Safeguards — Audit Controls	Logs are not integrated into a centralized logging system	Integrate logs from all hybrid components into a SIEM or centralized logging solution. Configure audit logging to capture all access attempts and administrative actions.
Technical Safeguards — Integrity	No integrity monitoring mentioned	Implement integrity monitoring to detect unauthorized modifications to PHI.
Technical Safeguards — Transmission Security	Data in transit is encrypted	No gap identified— encryption is properly

		configured for data in transit.
Technical Safeguards — Person or Entity Authentication	No MFA	Implement MFA to ensure users are who they claim to be. This is a critical gap.

4. Recommendations for Improvement

Based on the gaps in Sections 2 and 3, these are the measures I'd put forward. I've grouped them by priority, since some are urgent enough that they shouldn't wait behind the others. Each one notes what to do, why it matters, and how it helps with HIPAA.

Summary of Recommendations:

High Priority

- 1. Enforce Multi-Factor Authentication (MFA) for all users.**
Mitigates credential theft and unauthorized access to PHI.
- 2. Centralize key management and encrypt all backups.**
Improves key governance and protects backup data.
- 3. Implement periodic access reviews and automated user lifecycle management. (Priority: HIGH)**
Removes unnecessary privileges and disables inactive accounts promptly.
- 4. Establish centralized logging with automated alerting (SIEM).**
Improves visibility, correlation, and incident response.
- 5. Verify that a signed Business Associate Agreement (BAA) exists with the cloud provider. If absent, execute a HIPAA-compliant BAA.**
Ensures responsibilities for PHI protection are contractually defined.
- 6. Maintain ongoing security awareness training.**
Reinforce phishing awareness, secure cloud usage, and PHI handling.

Medium Priority

- 7. Upgrade on-premises firewalls and refine network security controls.**
Enables deep packet inspection and stronger segmentation.
- 8. Establish a vulnerability management program.**
Perform regular vulnerability scans (at least monthly) and remediate findings.
- 9. Formalize and test disaster recovery procedures.**
Define RTO/RPO, encrypt backups, and perform annual recovery testing.
- 10. Enhance centralized monitoring with file integrity monitoring.**

Detects unauthorized modification of PHI and critical system files.

Conclusion

Implementing these recommendations will strengthen the confidentiality, integrity, and availability (CIA) of Protected Health Information (PHI), reduce cyber risk within the hybrid cloud environment, and improve alignment with the HIPAA Security Rule's Administrative, Physical, and Technical Safeguards. Together with the completed shared responsibility analysis and HIPAA comparison sections from the report, these improvements represent an Excelled-level submission.